ONE-PAGE BRIEF

Post-quantum cryptography review: rustls @ 84bf9eaa9857

Client: rustls project — public repository (passive review) · Source: github.com/rustls/rustls, commit `84bf9eaa9857` · Reviewed: 2026-10-28 12:52 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 4 of 4

post-quantum by default in the critical paths

FINDINGS

0 Critical **6** High **6** Medium **13** Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 3 − 8 = 5 → **too late**

Signatures: 5 + 3 − 8 = 0 → **tight**

Next step: Keep the inventory current and review new code paths before release.

WHAT MATTERS MOST

High QSI-2026-05067	**Private key material present in bogo/keys/ecdsa_p256_key.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
High QSI-2026-05072	**Private key material present in bogo/keys/ecdsa_p384_key.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
High QSI-2026-05073	**Private key material present in bogo/keys/key.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
High QSI-2026-05079	**Private key material present in bogo/keys/rsa_1024_key.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...

21 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium channel key exchange (TLS, Noise, handshakes)	RSA, X25519	Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols)
Low role not determined	ECDSA, Ed25519	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 1; each needs checking against the code.

Static review of source code and manifests; files analysed: 137. No requests were sent to the owner's systems.

Full report, content SHA-256: `092f138746963e5313e56c6c6e1021a35d44fc24760a45e90140e65837152d06`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.